Merge Status Code

PROM06 REM-TC02b: remediation validation (comment updated) #98

Open abdulwaheed384 wants to merge 3 commits into `main` from `rem-tc02b`

Conversation 3 Commits 3 Checks 1 Files changed 1 +14

Reviewers

No reviews

Still in progress? Convert to draft

Assignees

No one—assign yourself

Labels

None yet

Projects

None yet

Milestone

No milestone

Development

Successfully merging this pull request may close these issues.

None yet

1 participant

abdulwaheed384 commented 3 hours ago Owner

PROM06 remediation validation, variant b for TC02: same AI-recommended fix as PR for rem-tc02, with the now-stale fixture comment updated to describe the restricted rule. Isolates whether the stale comment drove the AI re-review result. Research only: do not merge, do not apply.

Generated with Claude Code

https://claude.ai/code/session_019GGG1f33Kz2g4dpPAJoY44

Generated by Claude Code

abdulwaheed384 and others added 3 commits 4 hours ago

`PROM06 Evidences Collection TC02` ··· Unverified ✓ `3eda6f7`

`PROM06 remediation validation: apply AI-recommended fix for TC02` ··· Unverified ✓ `386c2ac`

`PROM06 remediation validation: TC02 fix with comment updated to match…` ··· Unverified ✓ `fd061b8`

github-actions Bot commented 3 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 7 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.

github-actions Bot commented 3 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_CLEAN
Findings: 0

No findings were reported.

github-actions Bot commented 3 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 95/100 — LOW — APPROVE
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 1 confirmed actionable finding(s).

Findings

- **LOW · SECURITY_VULNERABILITY · SSH allow rule applies to all subnet destinations rather than a specific target resource**
  - Category rationale: The AllowSSH rule (priority 300) permits TCP port 22 inbound from a single approved source address (203.0.113.10/32). While this is a significant improvement over an open rule, 203.0.113.10/32 is a single public IP address with no further restriction on destination addresses within the subnet (destination_address_prefix = '*'). *Any resource in the associated subnet is reachable on port 22 from this source. If multiple VMs or resources exist in the subnet now or in future, this expands the SSH attack surface beyond a single intended target. More critically, the destination_address_prefix of '*'* means the rule applies to all hosts in the subnet rather than a specific management IP, which is a concrete over-permissioning of the SSH allow rule as configured.
  - Evidence: azurerm_network_security_group.nsg, security_rule 'AllowSSH': source_address_prefix = '203.0.113.10/32', destination_port_range = '22', destination_address_prefix = '*', priority = 300, direction = 'Inbound', access = 'Allow'.
  - Analysis: The AllowSSH security rule in azurerm_network_security_group.nsg sets destination_address_prefix = '*', permitting the approved source (203.0.113.10/32) to reach TCP port 22 on any resource within the associated subnet (subnet-demo, 10.0.1.0/24). This is broader than necessary if the intent is to restrict SSH to a specific management host. Any current or future resource added to the subnet is automatically covered by this allow rule without requiring an explicit change.
  - Impact: All resources in subnet 10.0.1.0/24 are reachable on SSH port 22 from the approved source address. If additional VMs or services are deployed into this subnet, they inherit SSH exposure without any additional rule change, increasing the lateral movement and attack surface risk within the research environment.
  - Recommendation: Restrict destination_address_prefix to the specific IP address or prefix of the intended SSH management target (e.g., a specific VM private IP) rather than '*'. If the subnet is intended to host only one SSH-accessible resource, document this explicitly and consider tightening the destination when that resource's IP is known.

Recommendation

Review and remediate the confirmed findings above.

All checks have passed
2 successful checks

No conflicts with base branch
Merging can be performed automatically.

Merge pull request ▾ You can also merge this with the command line. View command line instructions.

Still in progress? Convert to draft